

NexusBox — QA findings and remediation plan

Source: /var/www/nexusbox/public/assets/.doc/qa-retest-2026-09-05/qa-retest-results.json
Target: http://10.0.10.155/login
Scope: Admin, Subscriber, Technician, authentication/API security
Original execution: Playwright Chromium, 5 September 2026
Recorded result: **237 passed · 28 failed · 11 blocked/inconclusive · 276 checks**

Executive conclusion

The system is not ready for production sign-off. The most important defects are the technician work-orders HTTP 500, HTTP transport without HTTPS enforcement, inconsistent Plan CRUD responses, and server-error handling for rejected CSRF requests. The notification and compact-sidebar failures are separate UI/authorization issues. Several repeated checks represent one shared defect, so the seven root causes below are more useful than counting each symptom as a separate bug.

ID	Priority	Consolidated root problem	Evidence	Proposed solution
R1	High	Technician work-orders page fails with HTTP 500.	PORTALS-0081/82; AUTH-022/24	Trace the server exception and dependency/query failure; add a friendly 5xx boundary and controller test.
R2	High	Login is available over HTTP without HTTPS redirect.	AUTH-025	Force HTTPS at reverse proxy and application layer; enable HSTS only after HTTPS is reliable.
R3	High	Plan CRUD responses are inconsistent with persistence. Create returned 500 while ID 79 existed; update/delete returned 422.	ADMIN-094/96/97/98	Make service transactions and response status match commit outcome; validate exact payload contract; add create-update-delete integration coverage.
R4	Medium	Invalid/missing CSRF is rejected but returns HTTP 500 instead of 419/403.	AUTH-034/35/47/48/60/61	Handle CSRF exceptions at the API boundary with a consistent 419 or 403 JSON response and no error-level server failure.
R5	Medium	Technician pages request notifications and receive HTTP 403.	PORTALS-0076/88	Separate portal notification feed permissions from admin/security events; return an allowed maintenance-only feed or avoid the request.
R6	Medium	Collapsed/mobile sidebar notification bell is outside the viewport and click times out.	ADMIN-107; PORTALS-0066/97	Unify mobile drawer and compact-rail state; constrain topbar layout at 390px; verify bell bounds after toggle.
R7	Low	Six admin pages contain unnamed combobox/switch controls.	ADMIN-007/43/46/52/55/70	Add explicit labels or aria-label/aria-labelledby tied to visible field labels; add accessibility assertions.

What passed

All three valid login flows reached their expected portals; session rotation, logout replay rejection, role boundaries, protected anonymous access, harmless SQL-injection input rejection, security headers, mobile overflow on most working pages, subscriber detail modals, and Scheduled Downtime disposable CRUD passed within their stated scope.

Failed test screenshots

These are the screenshots captured by the retest. Repeated screenshots are retained because each check is a separate recorded assertion. Checks without an image artifact are explicitly marked.

Implementation plan

Phase 0 — reproduce and instrument

1. Capture the exact exception and SQL/query inputs for the work-orders controller in a protected server log; do not expose internals to clients.
2. Re-run Plan CRUD with a unique disposable fixture and record database state plus HTTP response at each step.
3. Confirm deployed proxy scheme, trusted-proxy configuration, and session cookie Secure behavior.

Phase 1 — stabilize server contracts

1. Fix work-orders dependency/query/controller failure; return 200 for a valid page or a controlled error page with no uncaught 500.
2. Correct Plan create/update/delete validation and transaction boundaries so response status reflects persistence; guarantee cleanup.
3. Add centralized CSRF exception mapping to 419/403 JSON for API requests.
4. Define notification authorization: subscriber and technician feeds contain only permitted maintenance notices; login-attack notices stay out of subscriber feeds.

Phase 2 — fix shell and accessibility

1. Model sidebar states explicitly: expanded, compact rail, and mobile drawer. Section expansion must only affect labels/items in expanded mode.
2. At 390px, keep the bell inside the topbar viewport or move it into the drawer; test open, close, keyboard focus, and modal stacking.
3. Label every combobox and switch and assert accessible names in Playwright.

Phase 3 — deploy hardening and regression

1. Redirect HTTP to HTTPS at the edge and application fallback; then verify HSTS and Secure cookies.
2. Run the full suite sequentially per account to avoid session invalidation and include a controlled 30-minute expiry test in a staging environment.
3. Expand disposable CRUD fixtures for tickets/work-orders before testing their mutation paths; never guess existing IDs.

Acceptance criteria for closure

- Work-orders and all permitted portal pages load without 4xx/5xx runtime errors.
- Plan and downtime create, read, update, reload, delete, and old-record-preservation checks pass with truthful HTTP responses.
- Missing/invalid CSRF returns 419/403, never 500; no internal exception text is exposed.
- Only authorized maintenance notifications appear in subscriber/technician feeds; unread badge behavior remains persistent.
- Every menu icon is visible in compact mode at desktop and mobile widths; bell and modal are reachable and above the sidebar.
- HTTPS redirect, Secure/HttpOnly/SameSite cookies, role boundaries, login abuse resistance, and injection rejection pass in a clean staging run.

Test limitations

CRUD was fully exercised only for disabled Plans and Scheduled Downtime fixtures; ticket/work-order mutation was blocked because no safe cleanup endpoint or fixture existed. No charges, network deployment, live global settings, or existing-record deletion was attempted. The SQL-injection checks were harmless rejection probes, not an exhaustive penetration test. The report is a remediation plan, not a claim that the defects are fixed.